

SecureMailScope

Cryptographic Posture & Protocol Forensics for Mail Infrastructure

1. Executive Summary & Purpose

SecureMailScope is an automated forensic engine that audits email protocol cryptography directly from network packet captures (PCAP/PCAPNG). It evaluates SMTP, IMAP, and POP3 communications without requiring private server decryption keys, without installing intrusive host agents, and without reading or storing private email message bodies.

***The Core Analogy:** Inspecting email security with SecureMailScope is like inspecting an armored cash truck. You do not need to unlock or inspect the money inside the truck to verify that the exterior padlocks are intact, that the driver did not hand over the keys in cleartext, or that the security protocols were followed.*

2. The Problem: Why Email Cryptography is Fragile

Email relies on protocols designed in the early days of the Internet (SMTP, IMAP, POP3). Unlike modern web browsing (HTTPS) which is encrypted from the very first packet, email security is fraught with historical compromises:

- **STARTTLS Downgrade Attacks:** Mail connections typically start in plain text. A server announces the STARTTLS capability. If an active adversary or malicious middlebox strips this announcement from the cleartext banner, both mail servers fall back to unencrypted transmission without warning.
- **Cleartext Authentication Leaks:** Misconfigured clients and legacy relay agents frequently transmit credentials (AUTH LOGIN, AUTH PLAIN) before the TLS negotiation has completed, exposing account passwords in the clear.
- **Legacy Cipher Support:** Servers quietly maintain backward compatibility with cracked ciphers (RC4, 3DES, EXPORT) or deprecated protocol versions (SSLv3, TLS 1.0, TLS 1.1) that can be intercepted or decrypted offline.
- **Silent Configuration Drift:** Mail server updates or administrative oversights often revert hardened configurations back to insecure defaults over time.

3. Target Personas & Primary Use Cases

Target Role	Operational Workflow	Key Benefit
SOC & Incident Response	Investigating suspected mail interception or unauthorized credential leaks from network captures.	Provides exact packet frame numbers and copyable Wireshark filters proving flaws.
Mail Server Administrators	Hardening Postfix, Dovecot, Exim, or Exchange configurations prior to production deployment.	Copy-paste remediation snippets to close detected cipher/auth vulnerabilities.
Compliance & Security Auditors	Auditing corporate email cryptographic posture against NIST, ISO 27001, and HIPAA benchmarks.	Objective 0–100 posture scoring engine with reproducible mathematical deductions.
MSSPs & Security Engineers	Comparing baseline captures against new weekly or monthly traffic to track configuration drift.	Automated endpoint-by-endpoint diffing flagging degraded or improved security.

4. Technical Engine: 6-Stage Forensic Pipeline

SecureMailScope processes raw packet captures through a deterministic 6-stage analysis pipeline:

- Stage 1: TCP Stream Reassembly:** Raw packets captured out of order or fragmented are reassembled using dpkt into bidirectional TCP application streams across standard mail ports (25, 465, 587, 110, 143, 993, 995).
- Stage 2: Protocol & Dialog Extraction:** Reconstructs the full mail dialog state machine (SMTP EHLO/HELO, STARTTLS commands, IMAP CAPABILITY, POP3 STLS) and identifies whether the connection uses implicit TLS or explicit STARTTLS.
- Stage 3: Cryptographic Handshake Audit:** Parses TLS records: ClientHello and ServerHello parameters, negotiated TLS version, selected cipher suites, key exchanges, SNI, ALPN, JA3/JA3S client/server fingerprints, and X.509 certificate chains.
- Stage 4: 44 Heuristic Rules & AI Anomaly Detection:** Evaluates 44 deterministic security rules across cipher strength, authentication sequencing, and certificate validity. Concurrently runs an Isolation Forest Machine Learning model to detect statistical behavioral deviations.
- Stage 5: Objective Posture Scoring (0–100):** Applies credit-score-style mathematical scoring starting at 100 points, deducting weighted penalties based on flaw severity and exposure impact (e.g. -25 for cleartext auth before TLS, -15 for deprecated TLS).
- Stage 6: Evidence & Remediation Synthesis:** Binds each finding to the exact frame indices, generates copyable Wireshark display filters, and outputs vendor-specific remediation configuration blocks for Postfix, Dovecot, and Exim.

5. Application Modules & User Interface

Module	Route	Forensic Function
Landing Hub	/	Asymmetric product hero with active priority evidence preview and passive analysis boundaries.
PCAP Ingestion	/captures	Drag-and-drop upload zone (.pcap/.pcapng), SHA-256 verification, status tracking, and file inventory.
Executive Overview	/overview	Numeral posture score (0–100), letter grade (A–F), factor deduction bars, protocol/transport distributions.
Session Inspector	/sessions	Dense session table with sliding evidence drawer for TLS parameters, X.509 cert chains, and JA3 fingerprints.
Vulnerability Findings	/findings	Ranked vulnerability catalog with exact packet frame numbers, Wireshark filters, and remediation commands.
Posture Drift	/drift	Comparative baseline vs. current capture diffing flagging configuration regressions and upgrades.
Compliance Reports	/reports	Multi-format exports: raw JSON for SIEM/SOAR ingestion, standalone HTML briefs, and PDF executive summaries.

6. Architecture & Dual-Mode Runtime

SecureMailScope is engineered with a strict decoupled architecture:

- **Frontend Layer (Next.js 16 + TypeScript + Tailwind v4):** Dense, evidence-first forensic interface strictly compliant with WCAG AA contrast standards. Features custom typography (IBM Plex Sans, IBM Plex Mono, Source Serif 4) and tabular numerals.
- **Backend Layer (FastAPI + Python 3.13/3.14):** Asynchronous REST API utilizing dpkt for zero-subprocess packet parsing, cryptography for X.509 verification, and scikit-learn for anomaly modeling.
- **Fixture Mode (Default):** Set NEXT_PUBLIC_USE_FIXTURES=1 to explore the complete forensic engine immediately with realistic enterprise capture fixtures without dependencies.
- **Live Integration Mode:** Set NEXT_PUBLIC_USE_FIXTURES=0 to connect directly to the FastAPI server on port 8000 for live capture uploads and real-time packet reassembly.